

Prepared by : Tural Aghabalayev

Section 1: Executive Summary

Grand Marina Hotel is a large, high-occupancy hospitality facility with extensive guest services, dining operations, and event spaces, hosting more than 2,000 guests on peak nights. To support efficient operations and protect critical infrastructure, Hydroficient was contracted to install and maintain a centralized water flow management system across the property. Because this system directly supports hotel operations and guest safety, any security failure could lead to operational disruption, financial loss, or reputational damage. Threat modeling is essential to proactively identify risks, understand potential attack paths, and define appropriate security controls before vulnerabilities are exploited. Using a structured framework such as STRIDE allows stakeholders to clearly understand what must be protected, what could go wrong, and how to mitigate those risks.

Our analysis identified three critical concerns requiring immediate attention:

- Weak authentication controls and the absence of a formal security awareness training program increase the risk of unauthorized access to the system dashboard.
- Lack of network segmentation between hotel guest networks and operational systems expands the attack surface and could allow interception or manipulation of system data.
- Insecure or improperly managed cloud API access presents a risk of unauthorized control, data exposure, or service disruption.

Section 2: System Overview

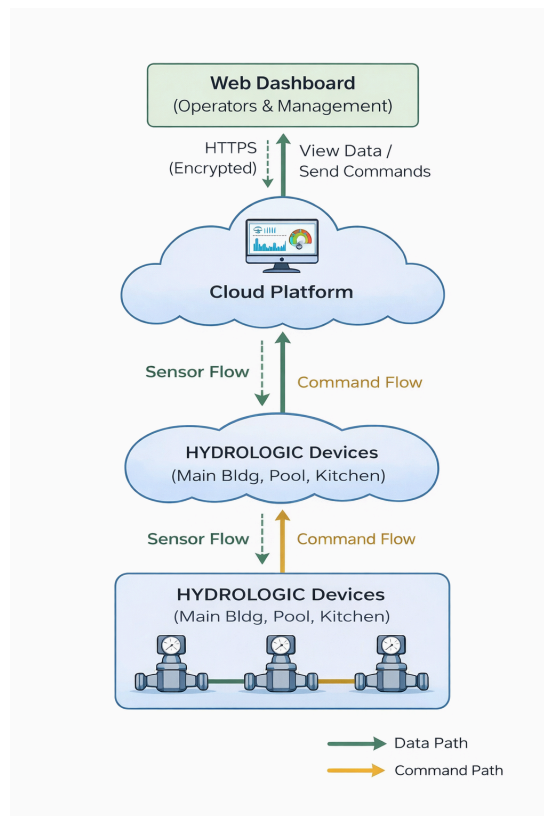
The Grand Marina Hotel is a 500-room luxury hospitality facility and a customer of Hydroficient's HYDROLOGIC water flow management platform. The system is deployed to monitor, control, and optimize water usage across critical hotel operations while supporting rapid response to leaks, abnormal pressure, or emergency conditions. The deployment consists of three HYDROLOGIC flow management devices, each installed on a dedicated water service line supporting different functional areas of the hotel. All devices communicate with a centralized cloud infrastructure that processes sensor data, stores historical records, and enables remote control actions. Authorized hotel operators and management access the system through a secure web-based dashboard that provides real-time visibility and operational control.

Core System Components

- Three HYDROLOGIC flow management devices (one per water service line)
- Pressure, flow rate, and gate position sensors
- Cloud-based API, data storage, and analytics services
- Web dashboard for operators and management
- Remote gate control and emergency shutoff mechanisms

Data and Control Flow Overview

The HYDROLOGIC system supports both continuous sensor data transmission and bidirectional command execution. Devices collect telemetry data including pressure, flow rate, and gate position and transmit it to the Hydroefficient cloud environment. The cloud processes this data, stores it in a database, and makes it available to the web dashboard for monitoring and reporting. When operators initiate actions such as gate adjustments or emergency water shutoff, commands are securely transmitted back through the cloud to the appropriate HYDROLOGIC device.



How the System Operates

1. HYDROLOGIC devices continuously measure water pressure, flow rate, and gate positions.
2. Sensor data is transmitted to the Hydrocient cloud using secure network connections.
3. Cloud services store and analyze incoming data, generating usage trends and alerts.
4. The web dashboard displays real-time and historical data to authorized users.
5. Operators can issue remote commands, including gate adjustments or emergency shutoff, which are executed by the devices.

Section 3: Asset Inventory

List the key assets and their CIA priorities (use your work from Step 2):

Asset	Description	C Priority	I Priority	A Priority
HYDROLOGIC Devices	3 flow management units	Medium	High	High
Web Dashboard	Operator monitoring interface	High	Critical	High
Cloud API	Device-to-cloud communication	High	High	Critical
Remote Controls	Gate adjustments, emergency shutoff	Low	High	High
Consumption Data	Savings reports, billing records	High	Medium	Medium

Section 4: STRIDE Analysis

This is the core of your threat model. For **each major component**, analyze all six STRIDE categories:

Component 1: HYDROLOGIC Devices

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker impersonates a legitimate HYDROLOGIC device and sends false telemetry data to the cloud platform.	Medium	High	High
Tampering	An attacker alters sensor readings or gate control signals, causing incorrect pressure levels or unintended valve movement.	Low	Critical	High
Repudiation	A malicious or negligent actor performs device actions (e.g., valve changes) without proper logging, making it difficult to trace responsibility.	Medium	Medium	Medium
Info Disclosure	Device telemetry (pressure, flow rate, usage patterns) is intercepted during transmission, revealing operational details of the hotel.	Medium	Medium	Medium
Denial of Service	The device is overwhelmed with traffic or deliberately disabled, preventing data transmission and remote control capabilities.	Low	Critical	High
Elevation of Privilege	An attacker exploits weak device authentication to gain administrative control over the device and its gate functions.	Low	Critical	High

Component 2:

Web Dashboard

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker uses stolen or weak credentials to impersonate a legitimate operator and access the dashboard.	Medium	Critical	High

Tampering	An attacker modifies dashboard settings or issues unauthorized commands that alter gate positions or disable alerts.	Low	Critical	High
Repudiation	An operator or attacker performs actions through the dashboard without sufficient audit logging, making actions difficult to trace.	Medium	High	Medium
Info Disclosure	Unauthorized access exposes real-time system data, usage reports, and operational details of the hotel.	Medium	High	High
Denial of Service	The dashboard becomes unavailable due to attack or overload, preventing operators from monitoring or controlling the system.	Low	Critical	High
Elevation of Privilege	A user with limited access exploits flaws to gain administrative control over dashboard functions.	Low	Critical	High

Component 3: Cloud API

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker impersonates a legitimate HYDROLOGIC device or cloud service to inject false data or accept unauthorized commands.	Medium	Critical	High
Tampering	Data or command messages are altered in transit or within the API, resulting in incorrect system behavior or device control.	Low	Critical	High
Repudiation	API requests or control actions are not properly logged, preventing attribution of malicious or erroneous activity.	Medium	High	Medium

Info Disclosure	API endpoints expose telemetry, credentials, or operational data due to misconfiguration or insufficient access controls.	Medium	High	High
Denial of Service	The API is flooded or disrupted, preventing devices from sending data or receiving control commands.	Medium	Critical	High
Elevation of Privilege	An attacker exploits API authorization flaws to gain higher-level access or administrative capabilities.	Low	Critical	High

Component 4: Remote Controls (Gate/Shutoff)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker sends forged control commands that appear to originate from an authorized operator or system.	Low	Critical	Medium
Tampering	Control commands are altered in transit, causing unintended gate movements or disabling emergency shutoff.	Low	Critical	Medium
Repudiation	Emergency actions or gate changes are executed without sufficient logging, making it difficult to determine who initiated them.	Medium	High	Medium
Info Disclosure	Control command metadata or system behavior is observed, revealing operational patterns or response procedures.	Low	Medium	Low
Denial of Service	Remote control functions become unavailable, preventing operators from responding to leaks or emergencies.	Low	Critical	High
Elevation of Privilege	A user with limited dashboard access gains permission to issue emergency shutdown or gate control commands.	Low	Critical	High

Section 5: Risk Summary

List your findings by risk level:

Critical Risks:

1. Unauthorized remote water control (Elevation of Privilege) — Compromise of the web dashboard, cloud API, or remote control functions could allow an attacker to issue gate adjustments or emergency shutoff commands. This could cause flooding, water outages, or delayed emergency response, directly impacting guest safety and hotel operations.
2. Cloud API denial of service (DoS) — All HYDROLOGIC devices rely on the cloud API for monitoring and control. A disruption to this service would disable visibility and remote response across the entire hotel, creating a single point of failure with immediate operational impact.
3. Weak authentication to control interfaces (Spoofing) — If dashboard or API authentication relies on weak credentials or lacks multi-factor authentication, a single compromised account could grant full system control. This presents a critical risk due to the system's centralized control model.
4. Command integrity compromise (Tampering) — Manipulation of control commands or sensor data could result in incorrect gate positioning or disabled safety mechanisms. This is critical because it can cause physical damage and unsafe conditions without immediate detection.

High Risks:

1. **Device or operator impersonation (Spoofing)** — An attacker could impersonate legitimate devices or operators, injecting false telemetry data or issuing unauthorized commands. This could lead to incorrect system decisions and delayed response to real incidents.
2. **Web dashboard service disruption (DoS)** — Loss of dashboard availability would prevent operators from monitoring system status or responding to abnormal conditions in a timely manner, increasing the duration and impact of incidents.
3. **Unauthorized data exposure via API or dashboard (Information Disclosure)** — Access to consumption data and operational telemetry could reveal usage patterns, system architecture, and business-sensitive information.
4. **Privilege escalation within dashboard roles (Elevation of Privilege)** — A user with limited permissions could exploit authorization flaws to gain administrative control, increasing the risk of system-wide compromise.
- 5.

Medium Risks:

1. **Insufficient audit logging (Repudiation)** — Incomplete logging of user actions and control events could make it difficult to determine responsibility during an incident or conduct forensic analysis.
2. **Telemetry interception (Information Disclosure)** — Interception of unencrypted or weakly protected telemetry data could expose operational details, though immediate safety impact is limited.
3. **False telemetry injection (Tampering)** — Injection of false sensor data could mask leaks or abnormal usage patterns, delaying detection and response.
4. **Command execution ambiguity (Repudiation)** — Lack of confirmation mechanisms for remote commands could create uncertainty about whether critical actions were successfully executed.

Section 6: Recommended Mitigations

For each Critical and high-risk, propose a defense:

Risk	Proposed Mitigation	Implementation Complexity
Weak dashboard authentication	Enable multi-factor authentication (MFA) and enforce strong password policies for all dashboard users	Low — configuration change
Unauthorized remote water control	Implement role-based access control (RBAC) and require elevated approval for gate and emergency shutoff actions	Medium — application configuration
Cloud API denial of service	Apply rate limiting, request validation, and monitoring on all API endpoints	Medium — cloud configuration
Command integrity compromise	Enforce end-to-end encryption and message signing for device telemetry and control commands	Medium — API and firmware updates
Cloud service single point of failure	Introduce limited local fail-safe operation with autonomous device behavior during cloud outages	High — architectural change

Device or operator impersonation	Require mutual authentication using certificates between devices, API, and dashboard	Medium – certificate management
Web dashboard service disruption	Deploy web application firewall (WAF) and basic DDoS protection mechanisms	Medium – cloud security services
Unauthorized data exposure	Perform regular access reviews and enforce separation of duties	Low – policy and application update
Privilege escalation within dashboard roles	Perform regular access reviews and enforce separation of duties	Low – policy and application update
Network exposure of devices	Segment HYDROLOGIC devices on isolated VLANs, separate from guest and business networks	Medium – network configuration